

The Quiet Attack Path

 horizon3.ai/attack-research/attack-blogs/the-quiet-attack-path

Justin Cady

October 21, 2025

How Attackers Own Active Directory in Minutes

If you've ever landed a low-privileged foothold in a Windows domain, you know the drill: enumerate everything, harvest Kerberos material, and stay quiet. This post walks through that attacker workflow—what happens in the first minutes, how techniques chain, and why it's so dangerous. Part 2 will show how to detect these behaviors with deterministic, low-noise signals.

TL;DR

- **Enumeration:** Quietly scrape Active Directory (AD) for users, descriptions, and Service Principal Names (SPNs) to find weak service and legacy accounts.
- **Kerberoasting:** Request Kerberos service tickets (TGS) for SPN accounts and crack offline.
- **AS-REP Roasting:** Request Authentication Service replies (AS-REP) for users with Kerberos pre-authentication (pre-auth) disabled and crack offline.
- **Why dangerous:** Native traffic, fast execution, pre-exploit timing, and often invisible to endpoint tools.
- **Prevalence:** These weaknesses appear in the majority of production environments we assess. They're also leveraged in the real world by serious threat actors and part of real attack campaigns with dire consequences.
- **Detection gap:** SIEM/EDR struggle because Kerberos traffic looks like normal admin activity, offline cracking is invisible, and signal-to-noise is high.

The Attacker's First 15 Minutes in Active Directory (AD)

From a valid user or a local admin beachhead, the workflow is boringly consistent:

1. **Scrape domain metadata.** Pull users, groups, and descriptions.

BloodHound/SharpHound, PowerView, Lightweight Directory Access Protocol (LDAP) queries—whatever's available.

```
Get-ADUser -Filter * -Properties Description,ServicePrincipalName | Select Name,Description,ServicePrincipalName
```

What we're really looking for: passwords in descriptions, service accounts, SPNs, misconfigs, and legacy flags.

```
# SharpHound collection (example)
```

```
Invoke-BloodHound -CollectionMethod ACL,LocalAdmin,Session,Trusts -NoSaveCache -
```

RandomizeFilenames

2. Kerberoasting. Request service tickets for accounts with SPNs. The crypto lands client-side; we take it offline and see what cracks.

```
# Signal of interest (attacker-side flow, simplified)
setspn -Q */*
# then request TGS for target SPNs and export for cracking
```

Other common tools:

```
# Impacket
GetUserSPNs.py -request -dc-ip <DC_IP> <DOMAIN>/<user>:<pass>
```

```
# Rubeus
Rubeus kerberoast /outfile:hashes.txt
```

Typical outcomes:

- Weak service account passwords can yield access to SQL/SharePoint/line-of-business (LOB) servers and enable lateral movement (e.g., linked servers, service contexts).
- Even if cracking fails, the SPN list identifies critical service accounts and trust edges.

3. AS-REP Roasting. For users with Kerberos pre-authentication (pre-auth) disabled, request an Authentication Service reply (AS-REP) without presenting any proof you are that user. Offline crack the response.

```
# Discovery often piggybacks on LDAP/AD queries
# then unauth AS-REQ to harvest AS-REP for cracking
```

Note: AS-REQ is the Kerberos Authentication Service request.

Other common tools:

```
# Impacket
GetNPUsers.py <DOMAIN>/ -dc-ip <DC_IP> -usersfile users.txt -format hashcat
```

```
# Rubeus
Rubeus asreproast /outfile:hashes.txt
```

Typical outcomes:

- Cracked user credentials enable Remote Desktop Protocol (RDP)/Server Message Block (SMB) access on non-hardened hosts, scheduled task/service deployment, and data access in that user's scope.
- Even without a crack, identified pre-auth disabled users reveal legacy risk to remediate.

None of this needs malware. *None of this looks noisy.* And most of it never hits your Security Information and Event Management (SIEM)/Endpoint Detection and Response (EDR) tools the way you think it does.

How Attackers Chain It Together

- **0–3 minutes: Recon at scale**
 - Enumerate users, groups, descriptions, SPNs via LDAP/PowerView/SharpHound.
 - Identify “too-helpful” descriptions, SPN-bearing accounts (likely services), and users with pre-auth disabled.
- **3–7 minutes: Kerberoasting collection**
 - Request TGS for target SPNs; export hashes for offline cracking.
 - Cracking time varies: minutes to hours with weak policy; effectively never with strong passwords.
 - Time-to-crack is driven by password length/complexity and cracking rules; strong policies make Kerberoast cracks effectively infeasible.
- **5–10 minutes: AS-REP Roasting collection**
 - Request AS-REP for pre-auth disabled users; export for offline cracking.
- **10–15 minutes: Pivot prep**
 - Use recon outputs (e.g., BloodHound graphs) to identify local admin paths and Tier-0 adjacencies (Domain Controllers and other identity-critical infrastructure).
 - Stage cracked creds/tickets for lateral movement, persistence, and privilege escalation.

Timings are indicative and depend on domain size, network latency, and password policy quality.

Why These Attacks Are So Dangerous

- **They’re pre-exploit.** These are reconnaissance and credential access steps that precede lateral movement, Local Security Authority Subsystem Service (LSASS) scraping, or DCShadow (Domain Controller Shadow)–grade ops.
 - Defensive implication: catching them here short-circuits the Attack Path before persistence and privilege escalation.
- **They’re native.** Pure Windows/Kerberos behavior; blends with legitimate admin activity.
 - Service Principal Name (SPN) enumeration and Kerberos ticket requests look like normal operations in Domain Controller (DC) logs.
 - Many environments lack fine-grained detection for the difference between benign and hostile usage of these flows.

- **They're fast.** Minutes from first foothold to viable crackable material.
 - Kerberoasting/AS-REP collection is a handful of queries and ticket requests; cracking can be queued while the operator keeps moving.
 - Unauthenticated AS-REP requests (when pre-auth is disabled) further reduce friction and visibility.
- **They're reliable.** Even if passwords don't crack, the enumeration reveals high-value targets and misconfig.
 - SPN-bearing user accounts are often service accounts with broad access; cracking one can unlock database/app servers and lateral movement.
 - Offline cracking is out-of-band: once hashes are exfiltrated, detection must come from the collection step—not the cracking itself.
 - Recon output (e.g., BloodHound graphs) exposes shortest paths to Tier-0; even failed cracks still map to effective next steps.

Prevalence in Real Environments

These AD attack techniques aren't edge cases—they're the norm. Based on autonomous pentesting operations across hundreds of production Active Directory environments:

- **Exposed credentials in AD attributes:** Observed in about one fifth of environments. Common patterns include passwords in the Description field, comments, or custom attributes intended for documentation but harvested by attackers during LDAP enumeration.
- **SPN-bearing user accounts (Kerberoastable):** Present in the majority of assessed domains. Service accounts with SPNs assigned to user objects (rather than managed service accounts) are widespread, and password policies often lag behind NIST/industry guidance.
- **Pre-authentication disabled (AS-REP Roastable):** Found in a notable minority of environments, typically legacy accounts or misconfigurations left over from migrations or compatibility workarounds.

The combination of these weaknesses creates multiple entry points for credential collection. Even environments with strong endpoint controls and patching cadence remain exploitable because these attacks leverage native Kerberos functionality that is difficult to prevent or monitor effectively.

If the Attack Succeeds: Likely Outcomes and Real World Consequences

At the very best, these techniques provide more insight into the environment, helping attackers find additional misconfigurations & targets, as well as map out efficient attack paths. At the very worst, attackers can escalate privileges to reach full domain compromise, giving them unfettered access to and control over sensitive data & critical

applications and the ability to establish persistence. They could potentially even extend access into cloud-based systems.

- **Service account compromise** via cracked SPN-bearing user → lateral movement to dependent servers (SQL/SharePoint/line-of-business apps).
- **AS-REP Roasting success** → user credential compromise that may enable RDP/SMB access, scheduled task/service deployment, or internal data access.
- **Graph-driven escalation** (e.g., BloodHound) → chaining local admin rights and group memberships toward Tier-0 assets (Domain Controllers and other identity-critical infrastructure) and Domain Admin.
- **Even without cracked creds**, reconnaissance reveals high-value paths and misconfigurations that reduce attacker time-to-objective.

Threat actors from nation-state actors to cybercriminals have successfully targeted Active Directory for dire consequences:

- **China-backed Volt Typhoon's stealth-focused campaigns against U.S. critical infrastructure** relied heavily on AD attacks. Volt Typhoon was able to compromise organizations in the communications, energy, transportation systems, and water & wastewater systems sectors with the intention to harvest sensitive data and disrupt functions and put infrastructure at risk.
- **Russia-backed NOBELIUM's supply-chain attack via the SolarWinds back door** leveraged kerberoasting as part of lateral expansion. The group gained access to U.S. federal agencies and private companies globally, likely exfiltrating significant amounts of sensitive data.

The Detection Gap: Why SIEM/EDR Miss These Attacks

Traditional security controls struggle with these techniques for several reasons:

- **Native protocol abuse.** Kerberos ticket requests (TGS, AS-REP) and LDAP queries are legitimate Windows operations. Distinguishing attacker enumeration from admin activity requires context that most SIEM rules lack.
- **No malware, no exploit signature.** Endpoint Detection and Response (EDR) tools excel at catching malicious binaries and exploit chains. These attacks use built-in Windows utilities (PowerShell, `setspn`, LDAP) or open-source tools (Impacket, Rubeus) that may be present in legitimate security testing or admin workflows.
- **Offline cracking is invisible.** Once the attacker exports Kerberos hashes (TGS-REP, AS-REP), cracking happens off-network. Detection must focus on the collection step—the ticket request—not the cracking outcome.
- **High signal-to-noise.** Domain Controllers generate thousands of 4769 (TGS requested) and 4768 (TGT requested) events daily. Without a way to isolate attacker-only interactions, defenders face alert fatigue and miss the critical signals.

- **Pre-exploit timing.** These attacks occur before traditional indicators of compromise (lateral movement, privilege escalation, data exfiltration). By the time defenders see downstream activity, the attacker already has credentials and a foothold.

MITRE ATT&CK Mapping

- Discovery:
 - [T1087 Account Discovery](#)
 - [T1069 Permission Groups Discovery](#)
 - [T1482 Domain Trust Discovery](#)
- Credential Access (Kerberos):
 - [T1558.003 Kerberoasting](#)
 - [T1558.004 AS-REP Roasting](#)

What's Next

Part 2 will show how purpose-built tripwire identities convert these ambiguous Kerberos behaviors into deterministic, low-noise detections. By seeding Active Directory with identities designed to be attractive to reconnaissance but unused by production, defenders can surface attacker-only interactions early in the Attack Path—before lateral movement, before privilege escalation, and with full context for rapid response.

Related Reading

- [From CVE-2022-33679 to Unauthenticated Kerberoasting \(Horizon3.ai research\)](#)
- [H3-2021-0038 \(Horizon3.ai Knowledge Base\)](#)
- [Metrics That Matter: An Attacker's Perspective on Assessing Password Policy](#)